SOP-IAM-03: Reset MFA (Lost or Replaced Phone)

Help the user back in with a new phone, without handing the account to an impostor

Project	**AccessGuard Health** — Horizon Valley Medical Center (HVMC) Healthcare IAM
SOP ID	SOP-IAM-03
Version / effective	1.0 / 9 November 2026
Owner	IAM Administrator (Sabitha S Karanavar)
Approved by	IT Security (Security Supervisor)
Review	Every 12 months, or after any incident or tooling change
Performed by	Help desk account **helpdesk.admin** (roles: Authentication Administrator + Reports Reader); never the Global Admin
Tool	`Invoke-HvmcMfaSupport.ps1 -Action Status | Reset | Verify`

1. Trigger

- User reports a lost, stolen, broken or replaced phone and cannot approve Microsoft Authenticator sign-ins
- Open a ticket (IAM-…) with priority High: the lost phone could still approve sign-ins

2. Verify the caller first (most important step)

- Call back on the phone number HR has on file, or confirm in person with photo ID, or confirmation from the manager
- Never trust the caller ID, an e-mail or a chat message alone; help-desk calls are a known way to take over accounts
- Admin accounts are **not** reset here (the script refuses); escalate to the IAM Administrator / break-glass process

3. Procedure

1. Status (read-only): `-Action Status`; note the current MFA methods and the time (ticket opened)
2. Dry run: `-Action Reset`; check the plan: revoke sessions, remove the MFA methods only
3. Apply: `-Action Reset -Apply -VerifiedBy "<how identity was checked>"`
4. Sessions are revoked first (the lost phone is signed out), then the MFA methods are removed; password and reset e-mail are kept
5. User signs in at `mysignins.microsoft.com/security-info` and registers the new phone **themselves**
6. About 10 minutes later: `-Action Verify`; expect 6/6 checks passed

4. Verify and evidence

- Entra audit log: “Admin deleted security info” by helpdesk.admin and “User registered security info” by the user
- Status / reset / verify evidence JSON (phone numbers masked) · ticket closed with opened/closed times and the identity-check method

5. Never

✗ Reset MFA before the identity check, or record a check that did not happen
✗ Ask the user for a code, approve a prompt for them, or register a method on their behalf
✗ Use the Global Admin for routine resets; reset the password too unless it was also requested
✗ Skip the session revoke; the lost phone may still hold a signed-in session

Example run: Ticket IAM-0004, Dr. Sarah Chen (5 Nov 2026): opened 3:25 PM, closed 3:54 PM, Verify 6/6. Improvement to evaluate: Temporary Access Pass after the identity check · System: Microsoft Entra ID (HVMC tenant, Free tier, security defaults on). Every change runs as a dry run first; nothing is changed without -Apply / --apply.